

APA Deployment Reference - OCI

Sovereign Landing Zone (Luna-rooted)

Deploying the Attested Provenance Architecture on OCI: hub-and-spoke landing zone, firewalled connectivity hub, network hub, DMZ over workloads, and a customer-controlled LunaDedicated HSM as the sovereign root of trust

James Patrick CITP MBCS

July 2026

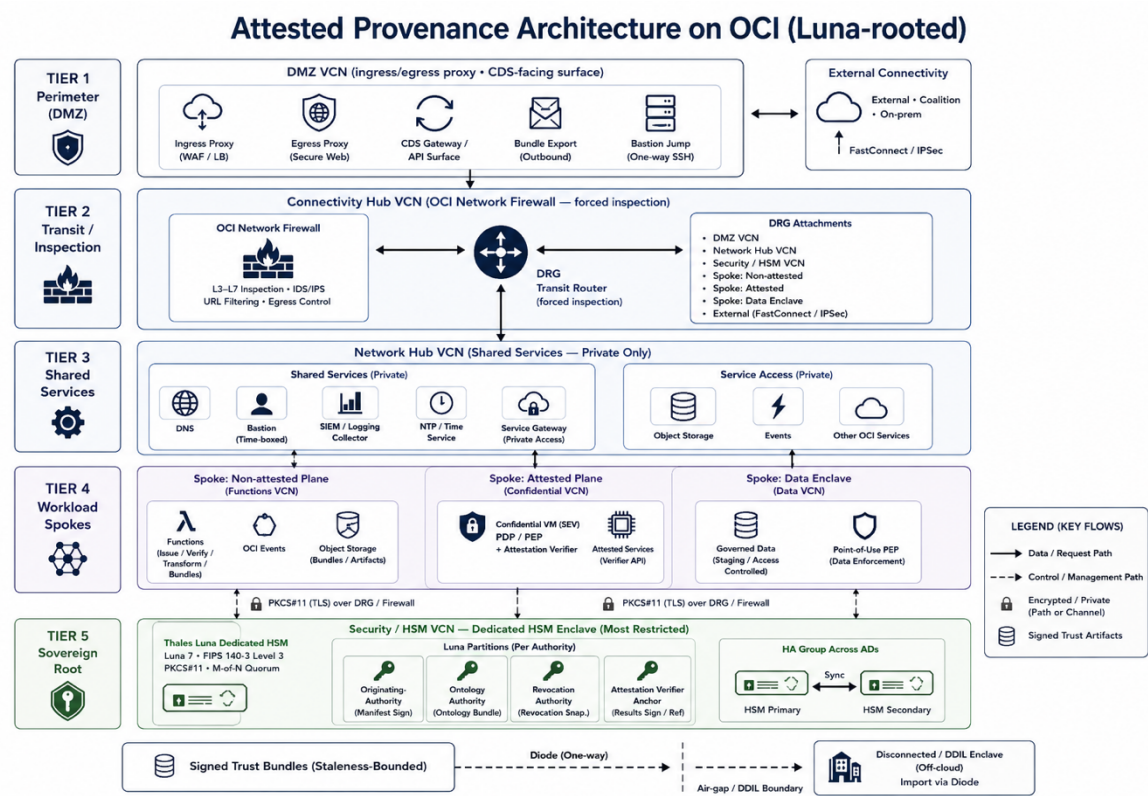


Figure 1 Deployment reference - draft v0.1, companion to the APA reference architecture

1. Purpose and Relationship to the Architecture

This document maps the Attested Provenance Architecture (APA) onto a concrete, accreditation-oriented OCI deployment. It resolves two of APA's hardest dependencies against real OCI primitives - the sovereign root of trust (§7.1) and attested point-of-use enforcement (§7.2) - and is explicit about the one that cannot be resolved inside a cloud region (disconnected/DDIL operation, §12).

The governing design decision is to **split APA by trust criticality** and place each half on the OCI service that fits it, rather than forcing the whole thing onto serverless Functions:

- the **non-attested plane** (issuance, verification, transformation, trust-bundle publication) runs as **OCI Functions** in a workload spoke;
- the **attested plane** (the PDP/PEP and the attestation verifier) runs in **OCI Confidential VMs** (AMD SEV), because a Function yields no tenant-controlled attestation report and therefore cannot make an enforceable decision;
- the **signing and trust-anchor roots** live in a **customer-controlled Luna Dedicated HSM**, so no signing key is ever visible to Oracle or leaves FIPS 140-3 Level 3 hardware.

2. Design Principles

1. **Sovereign root in customer hardware.** All authority signing keys are generated and used inside the Luna Dedicated HSM. Oracle has no access to the cryptographic material; administration is customer-only, under M-of-N quorum.
2. **Forced inspection.** DRG route tables hairpin every spoke-to-spoke and spoke-to-external flow through the OCI Network Firewall in the connectivity hub. No spoke peers directly with another.
3. **Separation of planes.** Attested and non-attested workloads occupy distinct spokes, compartments and IAM domains; the attested spoke is the most restricted.
4. **Fail-closed everywhere.** Absent attestation, a broken binding, an unverifiable trust artifact, or trust material past its staleness bound all resolve to deny (mirrors APA §3).
5. **Least privilege by construction.** One compartment per tier; Security Zones forbid public IPs on the workload, attested and HSM subnets and mandate encryption and approved shapes.
6. **Disconnected-aware.** The cloud LZ serves the connected and sovereign-enclave cases; the true air-gap/DDIL edge is handled by signed-bundle export across a diode and is explicitly out of the cloud control plane.

3. Landing-zone Topology

Tiers, top (least trusted) to bottom (most trusted): a DMZ above the workloads, a firewalled connectivity hub, a shared-services network hub, isolated workload spokes, and a dedicated HSM security enclave.

PKCS#11 signverifier keys | PKCS#11External | Coalition | On-premFastConnect / IPSecDMZ VCNingress/egress proxy | CDS-facing surfaceConnectivity Hub VCNOCI Network FirewallDRG - transit routerforced inspectionNetwork Hub VCNDNS | Bastion | SIEM | Service GatewaySecurity / HSM VCNdedicated HSM - Luna 7FIPS 140-3 L3 | PKCS#11Spoke: Non-attested planeFunctions: issue | verify | transform | bundlesObject StorageSpoke: Attested planeConfidential VM - SEVPDP/PEP + AttestationVerifierSpoke: Data enclavegoverned data | point-of-usePEP

- **DMZ VCN (above the workloads).** Terminates external, coalition and on-prem connectivity. Hosts ingress/egress proxies and the cross-domain-facing surface. This is where APA's ingress asymmetry (§13.4) lives: untrusted inbound receives full content inspection here; trusted outbound can use the fast binding-verify path once past the firewall.
- **Connectivity hub VCN.** The dedicated firewalled transit. The OCI Network Firewall enforces L3–L7 policy; the DRG is the transit router to which every spoke, the DMZ, the network hub and external links attach. Spoke route tables send all non-local traffic to the DRG, and DRG route tables steer it through the firewall - so inspection is unavoidable, not advisory.
- **Network hub VCN (shared services).** DNS, Bastion (time-boxed, audited administrative access - no standing SSH), logging/SIEM egress, and a Service Gateway for private access to OCI services (Object Storage, etc.) without traversing the internet.
- **Security / HSM VCN.** The Luna Dedicated HSM in a private subnet with no internet route, reachable over PKCS#11 from the signing services and the verifier. Most restricted compartment; administered under M-of-N quorum.
- **Workload spokes.** Non-attested plane (Functions + Object Storage), attested plane (Confidential VMs), and the data/point-of-use enclave - each its own VCN and compartment, attached to the DRG, never peered directly.

4. Root of Trust - Luna Dedicated HSM (APA §7.1)

The Luna is the sovereign PKI and trust-anchor root. Keys are generated in hardware and never exported; the provider has no cryptographic access.

Partitioning. Use cryptographically-separated Luna partitions per authority, so a compromise or mis-issuance in one does not touch another:

- originating/attribute-signing authority (manifest signatures),
- ontology authority (signs the federated ontology bundle),
- revocation authority (signs the revocation snapshot),
- attestation-verifier anchor (signs attestation results; holds reference values' trust anchor).

Access. Signing services connect over PKCS#11 (TLS) from their spokes via the DRG/firewall path; sensitive operations (key generation, policy change) require M-of-N quorum. Run the HSM in FIPS 140 approved mode; require FIPS 140-3 firmware (140-2 certificates become historical in September 2026).

PQC in hardware - and the archival choice this forces. Current Luna firmware performs ML-DSA (FIPS 204) in-hardware, so APA's **operational** signatures can be HSM-resident end to end. For the **archival** hash-based profile there is a real decision:

- **LMS/HSS (SP 800-208), in-HSM** - hardware-resident and hash-based, but *stateful*: it imposes rigorous one-time-key state management, and state reuse is catastrophic. Choose it only with disciplined state handling.
- **SLH-DSA (FIPS 205), application-side** - *stateless* and operationally simpler, but the key is not HSM-resident, so it forfeits the hardware root for the archival signature.

The honest recommendation: operational signing in-HSM with ML-DSA; for archival, prefer in-HSM LMS/HSS where state management can be assured, otherwise SLH-DSA app-side with the key protected by other means. State the trade explicitly in any accreditation submission.

Availability. Deploy at least two HSM appliances across availability/fault domains in a Luna HA group; plan backup-HSM handling and key ceremony separately.

5. Attestation - Confidential VMs, Customer-held Verifier (APA §7.2)

The PDP/PEP and the attestation verifier run in OCI Confidential VMs (AMD SEV). The workload requests a hardware-signed SEV attestation report; the verifier appraises it against reference values and releases the decision path only on an affirming result - the RATS flow APA models in `attestation.py`, now hardware-real for the runtime environment.

Two deliberate choices make the verification sovereign even though the SEV hardware root is AMD's:

- **host the verifier yourself**, in the attested spoke, rather than relying on any platform-hosted verifier; and
- **anchor the verifier's result-signing key and reference values in the Luna**, so the *integrity of the verdict* is customer-controlled.

Residual, stated plainly: the SEV attestation report ultimately chains to AMD's secure processor, which is not sovereign. This pattern mitigates that by making the verifier and its outputs sovereign and by gating data release on a verifier you control; it does not eliminate the AMD dependency. Where that residual is unacceptable, the enforcement enclave moves to a Dedicated Region, Cloud@Customer, or off-cloud hardware. Use Shielded Instances (Secure Boot, TPM, measured boot) for any non-confidential hosts as defence-in-depth.

6. Flows

Issuance / signing. Object created → OCI Events triggers the issuance Function (non-attested spoke) → PKCS#11 to the originating-authority Luna partition for the ML-DSA signature → signed manifest written to Object Storage via the Service Gateway. Egress traverses the firewall hub.

Enforcement at point-of-use. Request reaches the PDP (Confidential VM) → SEV attestation report → customer verifier (Luna-anchored) returns an affirming result → PDP verifies the manifest signature, checks the Luna-signed revocation snapshot and resolves the Luna-signed ontology, evaluates the classification (declared- transition state machine) → permit / deny, fail-closed on any failure.

Trust-bundle publication and disconnected export. Ontology and revocation Functions sign fresh bundles via their Luna partitions and publish to Object Storage. For a disconnected enclave, bundles are exported through the DMZ to a diode boundary and carried across with an explicit signed staleness bound - the point at which the flow leaves OCI entirely (APA §12).

7. Component-to-service Mapping

APA component	OCI placement	Trust tier
Attribute / ontology / revocation signing	Luna Dedicated HSM partitions (PKCS#11)	Sovereign root
Manifest issuance / verify / transform	OCI Functions (non-attested spoke)	Non-attested
Trust-bundle storage & distribution	Object Storage via Service Gateway	Non-attested
PDP / PEP	Confidential VM - SEV (attested spoke)	Attested

Attestation verifier	Confidential VM, keys in Luna	Attested / sovereign
Guardrails & segmentation	Landing Zone + Security Zones + compartments	Control plane
Inspection & transit	Network Firewall + DRG (connectivity hub)	Control plane
Ingress/egress & CDS surface	DMZ VCN	Perimeter
Sovereign-enclave / on-prem	Dedicated Region / Alloy / Isolated Region	Deployment posture

8. Guardrails and Accreditation Posture

Compartment per tier with distinct IAM; Security Zones to forbid public IPs on the workload, attested and HSM subnets, enforce encryption, and restrict the attested spoke to confidential shapes. All firewall, flow and audit logs to the SIEM under egress control. Connectivity into the connectivity hub via FastConnect and/or IPSec. The accreditation boundary (e.g. UK OFFICIAL-SENSITIVE vs SECRET) determines whether this runs in a commercial region, a Dedicated Region, or Cloud@Customer; that determination sits with the accreditor and is out of scope here.

9. Honest Limits

- **Functions-to-HSM latency.** Cold Functions establishing a PKCS#11 session per invocation will not suit high-volume issuance. For sustained signing throughput, run a persistent signing service on a (shielded/confidential) VM holding a long-lived HSM session, and reserve Functions for lower-rate or event-driven issuance.
- **AMD attestation root not sovereign.** Mitigated (customer verifier, Luna-anchored results), not eliminated.
- **Disconnected edge leaves OCI.** The cloud LZ serves the connected and enclave cases; true air-gap/DDIL is off-cloud by design.
- **LMS statefulness.** If chosen for the archival root, state management is a first-class operational risk, not a footnote.
- **Weight and cost.** This is a heavyweight pattern (Dedicated HSM commercial minimums, customer-run Luna, confidential compute). Justify it by classification level; do not apply it uniformly.

10. Build Sequence

1. Landing Zone guardrails, compartments, Security Zones, IAM domains.

2. Network hub and connectivity hub; DRG; Network Firewall; forced-inspection route tables; external connectivity.
3. DMZ VCN and ingress/egress surface.
4. Security/HSM VCN; provision the Luna Dedicated HSM; FIPS 140-3 mode; create per-authority partitions; M-of-N quorum; HA group and backup.
5. Attested spoke: Confidential VMs; deploy the PDP/PEP and the verifier; anchor verifier keys/reference values in Luna; validate the SEV attestation path end to end.
6. Non-attested spoke: Functions for issuance/verify/transform/bundles; Object Storage; Events wiring; PKCS#11 to Luna.
7. Data/enclave spoke and point-of-use PEP.
8. Wire the flows; validate against the APA reference implementation; test each fail-closed path (tamper, revocation, staleness, contraindicated attestation).